

VULNERABILITY ASSESSMENT

Report Summary
demo.testfire.net

PRESENTED TO
Future Interns

PRESENTED BY
Luthando Gongwana

EXECUTIVE SUMMARY

Overview of findings and strategic recommendations

A read-only vulnerability assessment was conducted on demo.testfire.net, a security testing environment maintained by IBM Security/HCL Technologies. The assessment focused on identifying security misconfigurations, missing security headers, and insecure cookie implementations.



Key Findings:

- 4 Medium-risk vulnerabilities were identified
- 4 Low-risk vulnerabilities were identified
- No critical vulnerabilities were found

Top Priorities:

1. Implement missing security headers (HSTS, X-Frame-Options, CSP)
2. Configure Secure flag on session cookies
3. Hide server version information

Overall Security Posture:

Fair - Immediate implementation of security headers recommended.

ASSESSMENT SCOPE

Target URL: <https://demo.testfire.net>
Assessment Type: Read-only external vulnerability assessment
Date: March 31, 2026



Methodology

- ✓ Network Scanning (Nmap)
- ✓ Security Header Analysis (Browser DevTools)
- ✓ Cookie Security Assessment
- ✓ Configuration Review

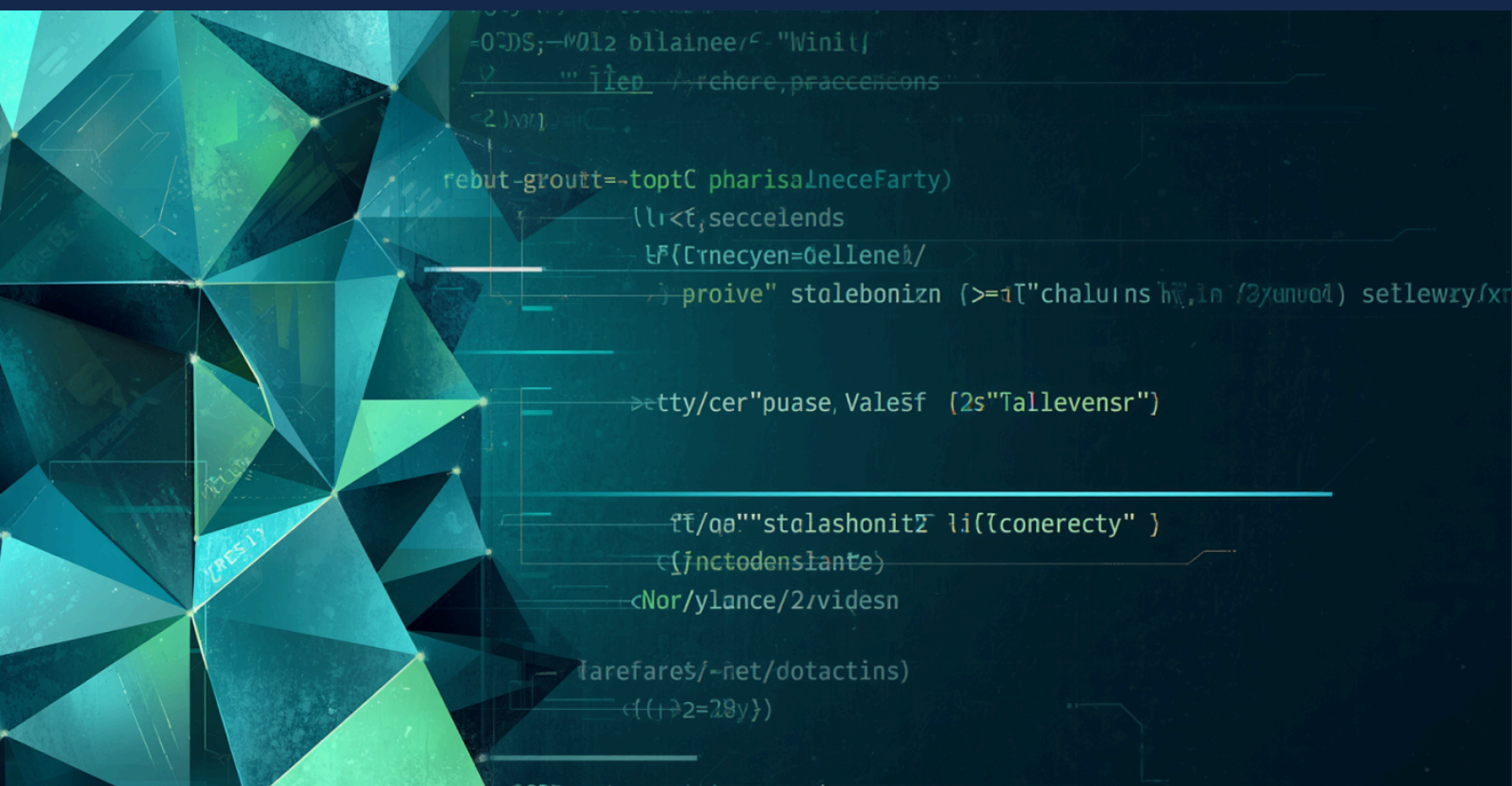
Tools Used

- Nmap - Port and service enumeration
- Chrome DevTools - Security header and cookie analysis
- GitHub - Documentation and evidence storage

RISK SUMMARY

Exploits and Risks

RISK LEVEL	COUNT	FINDINGS
HIGH	0	None identified
MEDIUM	4	Missing HSTS Missing X-Frame-Options Missing CSP Missing Secure Flag
LOW	4	Server Version Disclosure Missing X-Content-Type-Options Missing X-XSS-Protection Missing HttpOnly Flag



VULNERABILITIES

Finding 1: Missing HSTS Header

Field	Details
Risk Level	Medium
Location	HTTP Response Headers

Description:

The Strict-Transport-Security (HSTS) header is not present in HTTP responses. This header instructs browsers to only communicate with the website over HTTPS.

Business Impact:

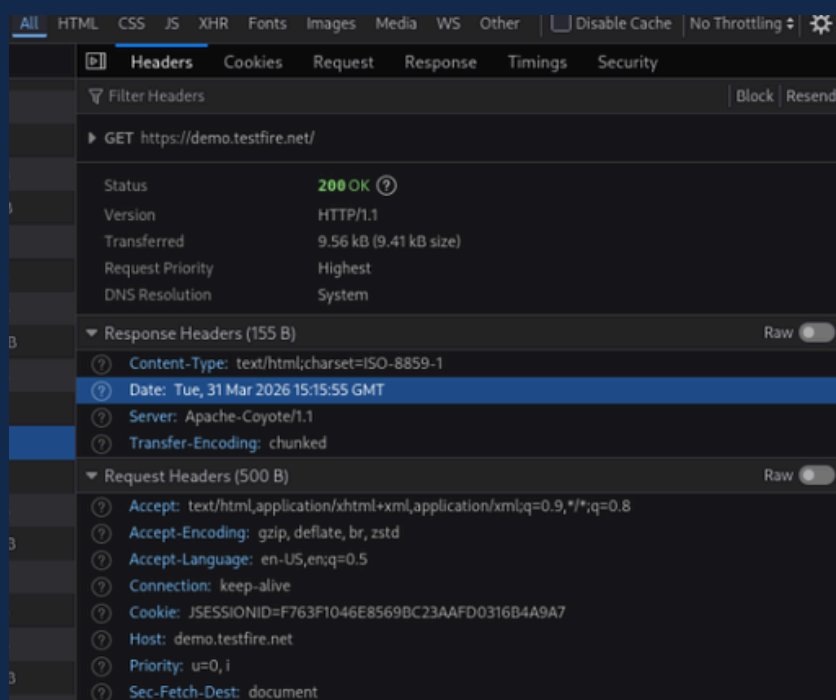
Users accessing the site over unsecured Wi-Fi networks could be downgraded to HTTP connections, allowing attackers to intercept sensitive data including login credentials.

Remediation:

Add the following header to server configuration:

Strict-Transport-Security: max-age=31536000; includeSubDomains

EVIDENCE:



Finding 2: Missing X-Frame-Options Header

Field	Details
Risk Level	Medium
Location	HTTP Response Headers

Description:

The X-Frame-Options header is missing, allowing the website to be embedded in iframes on external domains.

Business Impact:

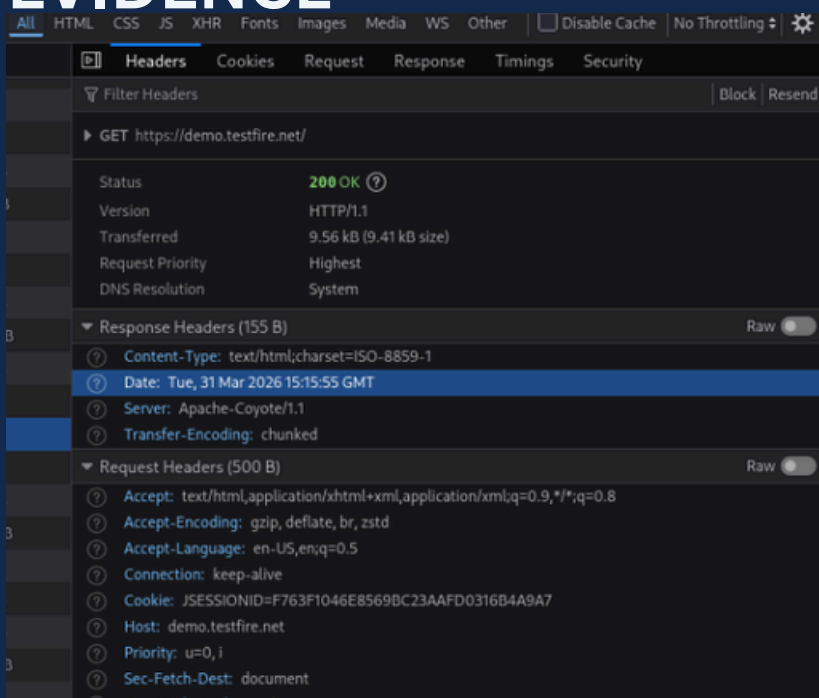
Attackers could create malicious websites that embed demo.testfire.net in invisible iframes, tricking users into clicking buttons or entering credentials (clickjacking attack).

Remediation:

Add the following header:

X-Frame-Options: SAMEORIGIN

EVIDENCE



Finding 3: Missing Content-Security-Policy

Field	Details
Risk Level	Medium

Description:

Content-Security-Policy (CSP) header is not implemented.

Business Impact:

Without CSP, if attackers find a way to inject malicious scripts into the website, browsers will execute them without restrictions.

Remediation:

Implement CSP header:

Content-Security-Policy: default-src 'self'; script-src 'self'; style-src 'self'

Finding 4: Cookie Missing Secure Flag

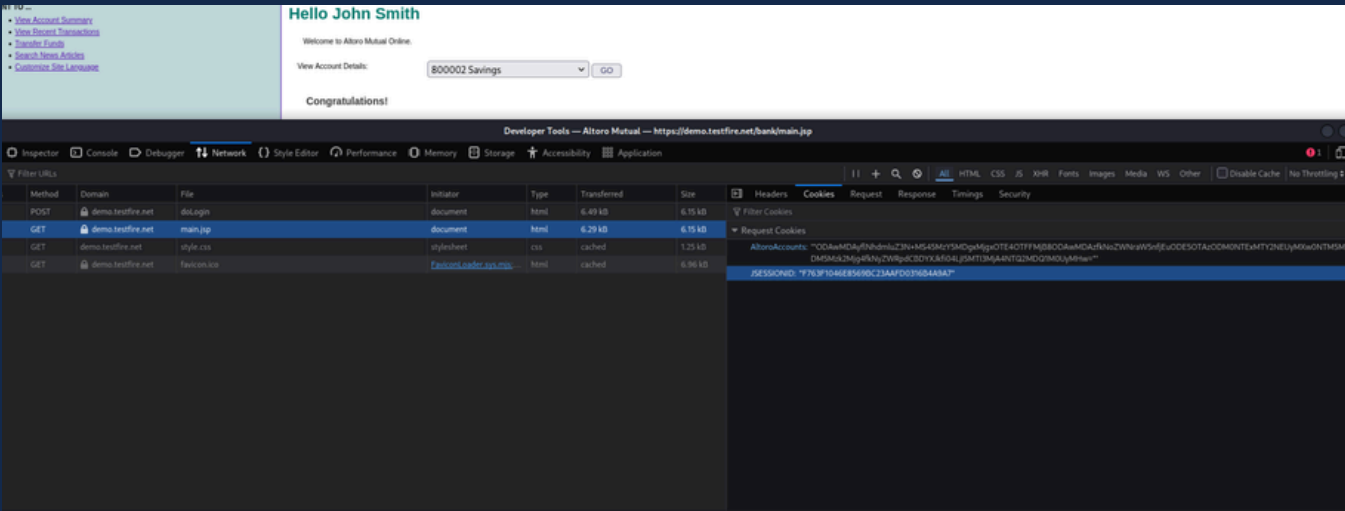
Field	Details
Risk Level	Medium
Location	JSESSIONID Cookie

Description:
The session cookie JSESSIONID is transmitted without the Secure flag.

Business Impact:
Session cookies can be transmitted over unencrypted HTTP connections. Attackers on the same network could intercept these cookies and hijack user sessions.

Remediation:
Configure the application to set Secure flag on all session cookies.

EVIDENCE



Finding 5: Server Version Disclosure

Field	Details
Risk Level	Low

Description:

HTTP responses reveal server information: Server: Apache-Coyote/1.1

Business Impact:

Attackers can research known vulnerabilities specific to Apache-Coyote 1.1 and target them accordingly.

Remediation:

Configure server to hide version information.

Finding 6: Missing X-Content-Type-Options

Field	Details
Risk Level	Low

Description:

X-Content-Type-Options: nosniff header is missing.

Business Impact:

Browsers may "sniff" MIME types, potentially leading to security issues with file uploads.

Remediation:

Add header: X-Content-Type-Options: nosniff

Finding 7: Missing X-XSS-Protection

Field	Details
Risk Level	Low

Description:

X-XSS-Protection header is missing.

Business Impact:

Modern browsers have built-in XSS filters, but this header ensures they are enabled.

Remediation:

Add header: X-XSS-Protection: 1; mode=block

Finding 8: Cookie Missing HttpOnly Flag

Field	Details
Risk Level	Low
Evidence	Console showing document.cookie reveals JSESSIONID

Description:

The session cookie is accessible via JavaScript as confirmed by document.cookie command.

Business Impact:

If an XSS vulnerability exists on the site, attackers could steal session cookies.

Remediation:

Set HttpOnly flag on session cookies.

RECOMMENDED ACTIONS BY PRIORITY

Immediate (Week 1)

- ☐ Implement HSTS header
- ☐ Add X-Frame-Options header
- ☐ Set Secure flag on all session cookies

Short-term

(Month 1)

- ☐ Implement Content-Security-Policy
- ☐ Configure HttpOnly flag on session cookies
- ☐ Add X-Content-Type-Options header

Ongoing

- ☐ Regular security header audits
- ☐ Hide server version information
- ☐ Conduct periodic vulnerability assessments

CONCLUSION

This vulnerability assessment identified 8 security findings on demo.testfire.net (4 medium risk, 4 low risk). No critical vulnerabilities were found.

Key Issues:

- Missing security headers (HSTS, X-Frame-Options, CSP)
- Session cookie missing Secure and HttpOnly flags
- Server version information exposed

What's Working Well:

- HTTPS is properly enforced (HTTP redirects to HTTPS)
- No exploitable vulnerabilities were found in this assessment

Recommendations:

Implement the missing security headers and configure session cookie flags within the next 30 days. These changes require minimal effort but significantly improve protection against clickjacking, session hijacking, and protocol downgrade attacks.

This report was prepared as part of the Future Interns Cyber Security Internship (Task 1).

